

Compte rendu – TP Gestion des sessions et protection CSRF

Nom : FOSSEUX

Prénom : Léo

Classe : Deuxième année de BTS SIO (Option SLAM)

Contexte :

Ce TP a pour objectif de comprendre le fonctionnement des sessions en PHP et de montrer comment une attaque CSRF peut exploiter une session active.

Il permet également de mettre en place une protection contre ce type d'attaque à l'aide d'un jeton CSRF.

Mise en place de l'environnement

Un serveur local PHP a été utilisé via XAMPP.

Un dossier tp_csrf a été créé dans le répertoire htdocs contenant les fichiers suivants :

login.php

profile.php

transfer.php

Le fichier attack.html, servant à simuler une attaque CSRF, a été placé en dehors du serveur web.

L'accès à http://localhost/tp_csrf/login.php permet d'afficher la page de connexion, ce qui confirme que l'environnement fonctionne correctement.

Connexion

Nom d'utilisateur :

Mot de passe :

s

Simulation d'une attaque CSRF

Après connexion avec les identifiants fournis (admin / password), l'utilisateur est redirigé vers la page profile.php.

Un transfert manuel est ensuite effectué depuis la page transfer.php, ce qui fonctionne normalement grâce à la session active.

Une page externe attack.html a été créée contenant un formulaire caché envoyant une requête POST vers transfer.php.

Lorsque cette page est ouverte alors que l'utilisateur est connecté, le transfert est exécuté sans que l'utilisateur en soit conscient.

Cela démontre que le site est vulnérable à une attaque CSRF lorsque aucune protection n'est mise en place.

Offre incroyable 

[Clique ici pour gagner !](#)

Mise en place de la protection CSRF

Pour sécuriser l'application, un jeton CSRF a été ajouté dans le fichier transfer.php.

Un jeton unique est généré avec random_bytes() et stocké dans la session.

Ce jeton est ajouté au formulaire de transfert via un champ caché.

Lors de la soumission du formulaire, le jeton reçu est comparé à celui stocké en session.

Si le jeton est absent ou incorrect, l'action est bloquée et un message d'erreur est affiché.

Tests après sécurisation

Après la mise en place du jeton CSRF :

Le transfert normal depuis le site fonctionne toujours correctement.

L'attaque via attack.html échoue et affiche un message indiquant qu'une attaque CSRF a été détectée.

CSRF détectée !

Cela confirme que la protection est efficace.

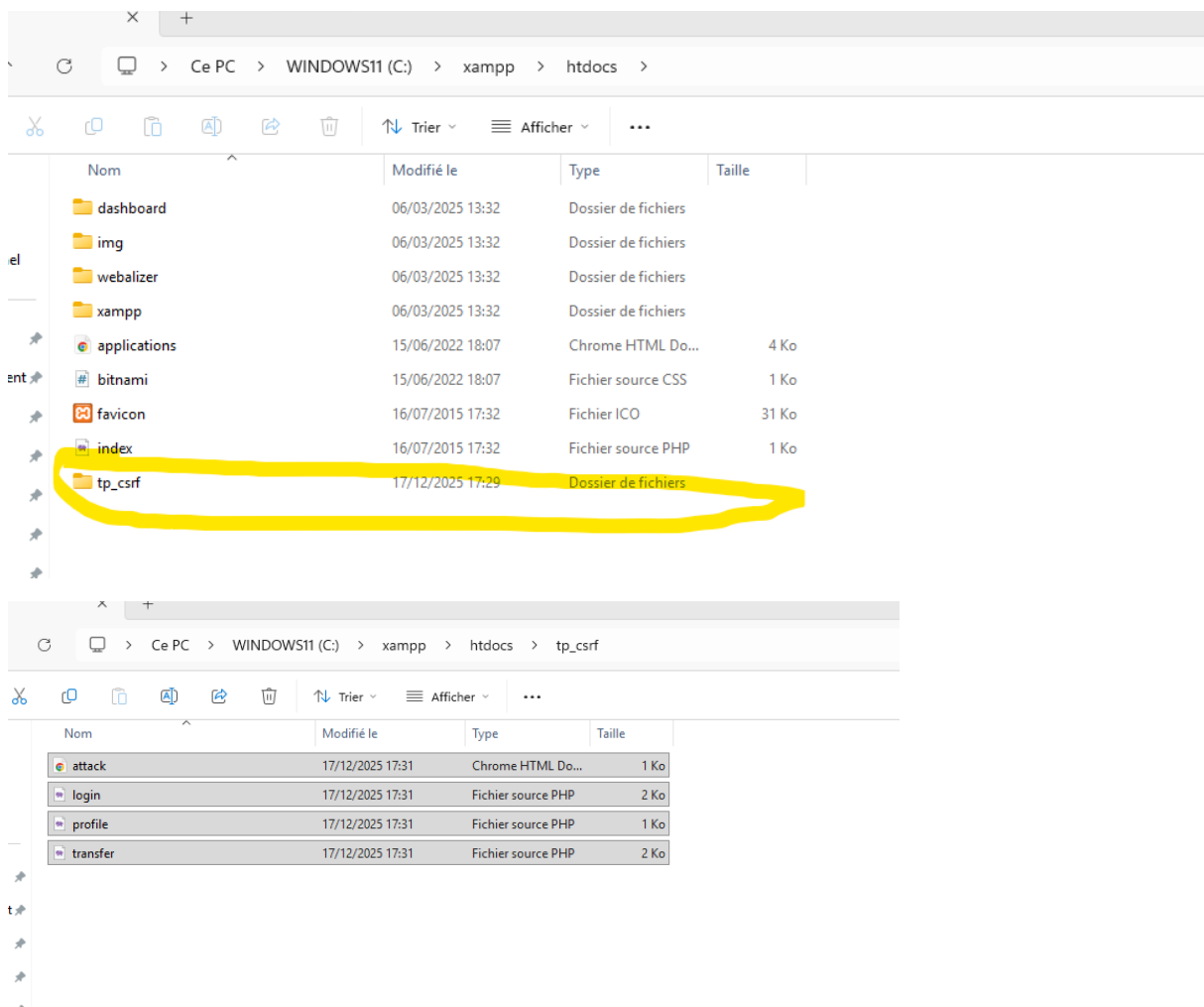
Conclusion :

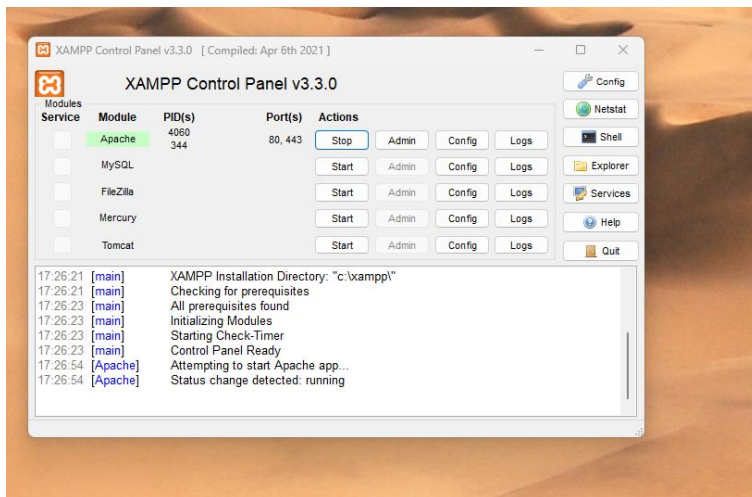
Ce TP montre que les attaques CSRF exploitent une session active pour exécuter des actions à l'insu de l'utilisateur.

La mise en place d'un jeton CSRF unique permet de vérifier l'origine des requêtes et de bloquer les actions frauduleuses.

Les tests réalisés confirment que la vulnérabilité est corrigée tout en conservant le bon fonctionnement du site.

Annexes :





Connexion

Nom d'utilisateur :

Mot de passe :

s

Bienvenue, admin

Vous êtes connecté. La session repose sur le cookie de session envoyé par votre navigateur.

[Faire un transfert](#) | [Se déconnecter](#)

Offre incroyable 🎁

Clique ici pour gagner !

Offre incroyable 🎁

Clique ici pour gagner !

Transférer des fonds (exemple protégé CSRF)

Transfert de 4500 € vers compte-destinataire effectué par admin.

Montant (€) :

Destinataire :

compte-destinataire

Transférer

[Retour profil](#) | [Se déconnecter](#)

CSRF détectée !